Cryptography and Embedded System Security
CRAESS_I

doc. Xiaolu Hou, PhD.

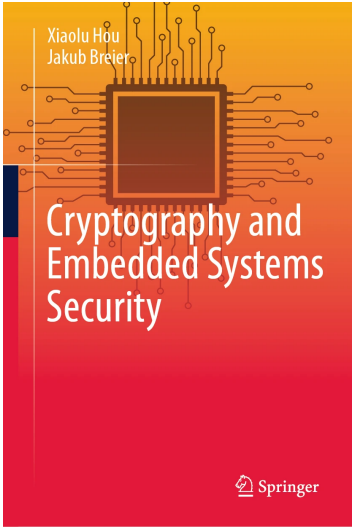
FIIT, STU
xiaolu.hou @ stuba.sk

Course Outline

- Abstract algebra and number theory
- Introduction to cryptography
- Symmetric block ciphers and their implementations
- RSA, RSA signatures, and their implementations
- Probability theory and introduction to SCA
- SPA and non-profiled DPA
- Profiled DPA
- SCA countermeasures
- FA on RSA and countermeasures
- FA on symmetric block ciphers
- FA countermeasures for symmetric block cipher
- Practical aspects of physical attacks
  - Invited speaker: Dr. Jakub Breier, Senior security manager, TTControl GmbH

Recommended reading

- Textbook
  - Sections
    - 1.7;
    - 4.1;
    - 4.2.1, 4.2.2, 4.2.3.



Lecture Outline

- Probability Measure
- Random Variable
- Side-channel Analysis
- Side-channel Leakages
- Leakage Assessment

Probability theory and introduction to SCA

- Probability Measure
- Random Variable
- Side-channel Analysis
- Side-channel Leakages
- Leakage Assessment

Random Experiments

- Probability theory studies the mathematical theory behind random experiments.
- A random experiment is an experiment whose output cannot be predicted with certainty in advance.
- However, if the experiment is repeated many times, we can see "regularity" in the average output.
- For example, if we roll a die, we cannot predict the output of one roll.
- But if we roll it many times, we would expect to see the number 1 in $1/6$ of the outcomes assuming the die is fair.

Sample Space and Events

- For a given random experiment, we define *sample space*, denoted by Ω, to be the set of all possible outcomes.
- A subset A of Ω is called an *event*.
- If the outcome of the experiment is contained in A, then we say that A has *occurred*.
- The empty set $\emptyset$ denotes the event that consists of no outcomes.
- $\emptyset$ is also called the *impossible event*.

Example

- When the random experiment is rolling a die, the sample space $\Omega = \{ 1, 2, 3, 4, 5, 6 \}$. $A = \{ 1, 2, 3 \} \subseteq \Omega$ is an event.
- When the random experiment is rolling two dice, $\Omega = \{ (i, j) \mid 1 \leq i, j \leq 6 \}$. One possible event is $A = \{ (1, 2), (1, 1) \}$.

Events

- Recall that we defined complements, unions, and intersections of sets in the first week.
- Fix a sample space Ω. Take events $A, B, A_1, \ldots, A_n \subseteq \Omega$.
- We say that $A \cup B$ occurs if either A or B occurs.
- More generally, $\bigcup_{i=1}^{n} A_i$ occurs when at least one of the events A_i occurs.
- We say that $A \cap B$ occurs if both A and B occur.
- Similarly, $\bigcap_{i=1}^{m} A_i$ occurs if all of the events A_i occur.
- If $A \cap B = \emptyset$, then A and B cannot both occur; they are called *mutually exclusive*.
- The complement of A, denoted by A^c, consists of all outcomes in Ω that are not in A.

Sample space and its power set

- Ω: sample space
- $\mathcal{A}$: power set of Ω, 2^{Ω}

Example

Let us consider the random experiment of tossing a coin, the sample space $\Omega = \{ H, T \}$. $\mathcal{A} = 2^{\Omega} = \{ \emptyset, \Omega, \{ H \}, \{ T \} \}$.

Probability

Definition

A *probability measure* defined on $(\Omega, \mathcal{A})$ is a function $P : \mathcal{A} \to [0, 1]$ such that

- $P(\Omega) = 1$, $P(\emptyset) = 0$.
- For any $A_1, A_2, \ldots \in \mathcal{A}$ that are pairwise disjoint, i.e. $A_{i_1} \cap A_{i_2} = \emptyset$ for $i_1 \neq i_2$, *countable additivity*

$$P\left(\bigcup_{i=1}^{\infty} A_i\right) = \sum_{i=1}^{\infty} P(A_i).$$

$P(A)$ is called the *probability* of A.

Example

Tossing a coin, $\Omega = \{ H, T \}$. $\mathcal{A} = 2^{\Omega} = \{ \emptyset, \Omega, \{ H \}, \{ T \} \}$. P defined as follows is a probability measure on $(\Omega, \mathcal{A})$:

$$P(\emptyset) = 0, \quad P(\Omega) = 1, \quad P(\{ H \}) = \frac{1}{2}, \quad P(\{ T \}) = \frac{1}{2}.$$

Uniform probability

Definition

Let Ω be a set with finite cardinality. $\mathcal{A} = 2^{\Omega}$. A probability measure P on $(\Omega, \mathcal{A})$ is called *uniform* if

$$P(\{\, \omega \,\}) = \frac{1}{|\Omega|}, \ \forall \omega \in \Omega.$$

If P is a uniform probability measure on $(\Omega, \mathcal{A})$, then for any $A \in \mathcal{A}$, $P(A) = \dfrac{|A|}{|\Omega|}$.

Example

Let $\Omega = \{\, 1, 2, 3, 4, 5, 6 \,\}$ and $\mathcal{A} = 2^{\Omega}$. The uniform probability measure on $(\Omega, \mathcal{A})$ is given by P such that

$$P(\{\, i \,\}) = \frac{1}{6}$$

for $i \in \Omega$. Let $A = \{\, 1, 2, 3 \,\}$, $B = \{\, 2, 4 \,\}$, then

$$P(A) = \frac{1}{2}, \quad P(B) = \frac{1}{3}.$$

Probability measure on a countable set

Example

Let Ω be a countable set (finite or countably infinite). Let $\mathcal{A} = 2^{\Omega}$. Then, any probability measure on $(\Omega, \mathcal{A})$ is a function such that for any $A \in \mathcal{A}$,

$$P(A) = \sum_{\omega \in A} P(\{\,\omega\,\}), \text{ where } P(\{\,\omega\,\}) \geq 0 \text{ and } \sum_{\omega \in \Omega} P(\{\,\omega\,\}) = 1.$$

Conditional probability

- Take any $A, B \in \mathcal{A}$ such that $P(B) > 0$.
- We would like to compute the probability of A occurring given the knowledge that B has occurred.
- We do not need to consider $A \cap B^c$ since B has already occurred.
- Instead, we look at $A \cap B$, which occurs when both A and B occur.
- This leads to the definition of the *conditional probability of A given B*:

$$P(A|B) := \frac{P(A \cap B)}{P(B)}.$$

Example

- $\Omega = \{ 1, 2, 3, 4, 5, 6 \}$, $\mathcal{A} = 2^{\Omega}$
- P: the uniform probability measure on $(\Omega, \mathcal{A})$; $P(\{ i \}) = \dfrac{1}{6}$ for $i \in \Omega$.
- $A = \{ 1, 2, 3 \}$, $B = \{ 2, 4 \}$.

$$A \cap B = \{ 2 \}, \quad P(A \cap B) = \frac{1}{6}, \quad P(A|B) = \frac{P(A \cap B)}{P(B)} = \frac{1/6}{1/3} = \frac{1}{2}$$

Independent events

Definition

Two events A, B are said to be *independent* if $P(A \cap B) = P(A)P(B)$. Otherwise, we say that they are *dependent*.

When $P(B) > 0$, the condition $P(A \cap B) = P(A)P(B)$ is equivalent to

$$P(A|B) = \frac{P(A \cap B)}{P(B)} = \frac{P(A)P(B)}{P(B)} = P(A).$$

That is, the probability of A occurring given the knowledge that B has occurred is the same as the probability of A occurring without the knowledge that B has occurred.

Independent events

Example

Let $\Omega = \{ 1, 2, 3, 4, 5, 6 \}$ and $\mathcal{A} = 2^{\Omega}$. The uniform probability measure on $(\Omega, \mathcal{A})$ is given by P such that for $i \in \Omega$:

$$P(\{ i \}) = \frac{1}{6}.$$

$$A = \{ 1, 2, 3 \}, \quad B = \{ 2, 4 \}, \quad P(A) = 1/2, \quad P(B) = 1/3,$$

$$A \cap B = \{ 2 \}, \quad P(A \cap B) = \frac{1}{6}, \quad P(A|B) = \frac{P(A \cap B)}{P(B)} = \frac{1/6}{1/3} = \frac{1}{2}$$

$$P(A)P(B) = \frac{1}{2} \times \frac{1}{3} = \frac{1}{6}.$$

By definition, A and B are independent. We also note that

$$P(A|B) = P(A) = \frac{1}{2}.$$

Bayes' Theorem

Theorem (Bayes' Theorem)

If $P(A) > 0$ and $P(B) > 0$, then

$$P(B)P(A|B) = P(A)P(B|A).$$

Proof.

Since

$$P(A|B) = \frac{P(A \cap B)}{P(B)}, \quad P(B|A) = \frac{P(A \cap B)}{P(A)}$$

we have

$$P(B)P(A|B) = P(A \cap B), \quad P(A)P(B|A) = P(A \cap B).$$

□

Partition of Ω

Definition

A set of events $\{ E_1, E_2, \ldots \mid E_i \in \mathcal{A} \}$, is called a *partition of* Ω if they are pairwise disjoint, $P(E_i) > 0$ for all i, and $\cup_i E_i = \Omega$. If the set of events is finite, it is called a *finite partition of* Ω, otherwise, it is called a *countable partition of* Ω.

Example

Let $\Omega = \{ 1, 2, 3, 4, 5, 6 \}$, $\mathcal{A} = 2^{\Omega}$, and P be the uniform probability measure on $(\Omega, \mathcal{A})$. Let $E_1 = \{ 1, 2, 3 \}$, $E_2 = \{ 4, 5 \}$, $E_3 = \{ 6 \}$. Then, $\{ E_1, E_2, E_3 \}$ is a finite partition of Ω. We can also calculate that

$$P(E_1) = \frac{1}{2}, \quad P(E_2) = \frac{1}{3}, \quad P(E_3) = \frac{1}{6}.$$

Lemma

Lemma

Let $\{ E_1, E_2, \ldots \mid E_i \in \mathcal{A} \}$ *be a finite or countable partition of* Ω*. Then, for any* $A \in \mathcal{A}$*, we have*

$$P(A) = \sum_i P(A|E_i)P(E_i).$$

Example

$\Omega = \{ 1, 2, 3, 4, 5, 6 \}$, $E_1 = \{ 1, 2, 3 \}$, $E_2 = \{ 4, 5 \}$, $E_3 = \{ 6 \}$, $A = \{ 2, 4 \}$.

$$P(A) = \frac{1}{3}, \quad A \cap E_1 = \{ 2 \}, \quad A \cap E_2 = \{ 4 \}, \quad A \cap E_3 = \emptyset.$$

$$P(A|E_1) = \frac{1/6}{1/2} = \frac{1}{3}, \quad P(A|E_2) = \frac{1/6}{1/3} = \frac{1}{2}, \quad P(A|E_3) = 0.$$

$$\sum_{i=1}^{3} P(A|E_i)P(E_i) = \frac{1}{3} \times \frac{1}{2} + \frac{1}{2} \times \frac{1}{3} = \frac{1}{3} = P(A).$$

A generalized version of Bayes' Theorem

Theorem

Let $\{ E_1, E_2, \ldots \mid E_i \in \mathcal{A} \}$ *be a finite or countable partition of* Ω*. For any* $A \in \mathcal{A}$ *with* $P(A) > 0$ *and any* m*, we have*

$$P(E_m|A) = \frac{P(A|E_m)P(E_m)}{\sum_i P(A|E_i)P(E_i)}.$$

Proof.

By Bayes' Theorem

$$P(E_m|A) = \frac{P(A|E_m)P(E_m)}{P(A)}.$$

The result then follows from the previous Lemma. □

Probability theory and introduction to SCA

- Probability Measure
- Random Variable
- Side-channel Analysis
- Side-channel Leakages
- Leakage Assessment

Definition

Definition

A *random variable* X is a function $X : \Omega \to \mathbb{R}$ satisfying suitable measurability conditions. In this course, we can think of a random variable as a rule that assigns a real number to each outcome in Ω.

Example

Let us consider the random experiment of tossing a coin, the sample space $\Omega = \{ H, T \}$. Define $X : \Omega \to \mathbb{R}$ such that

$$X(H) = 0, \;\; X(T) = 1.$$

Then X is a random variable.

Example of a random variable – indicator function

Example

Fix $A \in \mathcal{A}$, the *indicator function*, denoted 1_A, for A is defined as follows:

$$1_A : \Omega \to \mathbb{R}, \quad 1_A(\omega) = \begin{cases} 1 & \omega \in A \\ 0 & \omega \notin A \end{cases}.$$

1_A is a random variable.

Distribution

Let X be a random variable, define P^X as follows:

$$P^X : \mathcal{R} \to [0,1], \quad B \mapsto P(X^{-1}(B)).$$

We say that P^X is *induced* by X and it is called the *distribution* of X.
Here $\mathcal{R}$ denotes the *Borel sets* (more precisely, the Borel σ-algebra), a collection of subsets of $\mathbb{R}$ that contains open sets, closed sets, and many other sets obtained from them.

Remark

For simplicity, we will write $P(X \in B)$ instead of $P(X^{-1}(B))$. For example, we write $P(X \leq x)$ instead of $P(X^{-1}((-\infty, x]))$.

CDF

The *cumulative distribution function (CDF)* of X, denoted F, is defined as

$$\begin{aligned} F : \mathbb{R} &\rightarrow [0,1] \\ x &\mapsto P^X((-\infty, x]) = P(X^{-1}((-\infty, x])) = P(X \leq x) \end{aligned}$$

Continuous random variable

When the distribution function $F(x) = P(X \leq x)$ has the form

$$F(x) = \int_{-\infty}^{x} f(y)dy$$

we say that X has *probability density function (PDF)* f and X is called a *continuous random variable*.

Remark

When Ω is a countable set (finite or countably infinite), X is a discrete random variable. But we will focus on continuous random variables.

Example – continuous random variable

Example

Define $f(x) = 1$ for $x \in (0, 1)$ and 0 otherwise. $F(x) = \int_{-\infty}^{x} f(y)dy$, is given by

$$F(x) = \begin{cases} 0 & x \leq 0 \\ x & 0 \leq x \leq 1 \\ 1 & x > 1 \end{cases}.$$

If X is a random variable that has F as its CDF, then we say that X induces a *uniform distribution* on $(0, 1)$.

Standard normal distribution

Example

A random variable Z that induces a *standard normal distribution* has probability density function

$$f(z) = \frac{1}{\sqrt{2\pi}} \exp\left(-\frac{z^2}{2}\right),$$

and cumulative distribution function

$$\Phi(z) = \frac{1}{\sqrt{2\pi}} \int_{-\infty}^{z} \exp\left(-\frac{y^2}{2}\right) dy.$$

- Standard normal distribution will be very useful in later parts of the course and we use $\Phi(z)$ instead of $F(z)$ to denote its CDF.
- We say that Z is a *standard normal random variable*.

Standard normal distribution

Example

The following figure shows that $f(z)$ is a bell-shaped curve that is symmetric about 0. The symmetry is also apparent from the formula for $f(z)$.

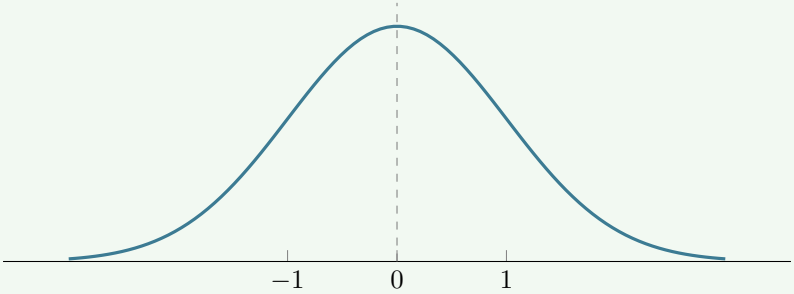


Figure: Probability density function of the standard normal random variable

Expectations and Variances

- The *expectation/mean* of a random variable X is the expected average value of X.
- And the *variance* of X is the average squared distance from the mean.
  - By squaring the distances, the small deviations from the mean are reduced and the big ones are enlarged.
  - Thus the variance measures how the values of X vary from the mean or how "spread out" the values of X are.

Expectation of a continuous random variable

When X is a continuous random variable with PDF f, its *expectation/mean* is defined as

$$\mathrm{E}[X] = \int_{-\infty}^{\infty} x f(x) dx.$$

provided the integral exists.

Example

X induces a *uniform distribution* on $(0, 1)$. X has PDF $f(x) = 1$ for $x \in (0, 1)$ and 0 otherwise.

$$\mathrm{E}[X] = \int_{-\infty}^{\infty} x f(x) dx = \int_0^1 x dx = \left.\frac{x^2}{2}\right|_0^1 = \frac{1}{2}.$$

Expectation of the standard normal random variable

When X is a continuous random variable with PDF f, its *expectation/mean* is defined as

$$\mathrm{E}[X] = \int_{-\infty}^{\infty} x f(x) dx.$$

provided the integral exists.

Example

Let Z be a random variable that induces the standard normal distribution. Then

$$f(z) = \frac{1}{\sqrt{2\pi}} \exp\left(-\frac{z^2}{2}\right),$$

and

$$\mathrm{E}[Z] = \int_{-\infty}^{\infty} z f(z) dz = \frac{1}{\sqrt{2\pi}} \int_{-\infty}^{\infty} z \exp\left(-\frac{z^2}{2}\right) dz = 0.$$

Integral of an odd function with limits $-\infty$ and ∞ is zero.

Expectation of the standard normal random variable

Example

As shown in the following figure, $f(x)$ is symmetric about 0, so it is not surprising that the expected average value of Z is 0.

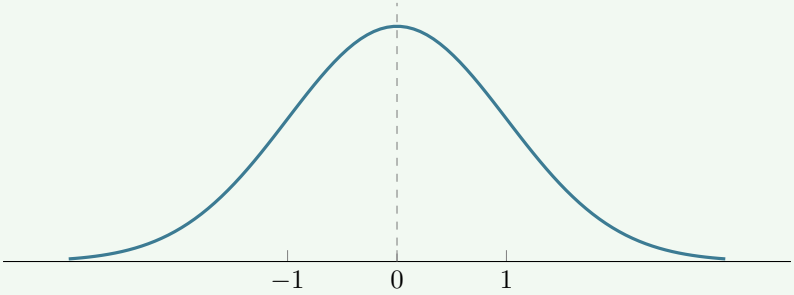


Figure: Standard normal distribution.

Some properties of expectations

- Given two random variables X, Y such that $\mathrm{E}\left[|X|\right] < \infty, \mathrm{E}\left[|Y|\right] < \infty$
- For any $a, b \in \mathbb{R}$

$$\mathrm{E}\left[X+Y\right] = \mathrm{E}\left[X\right] + \mathrm{E}\left[Y\right], \quad \mathrm{E}\left[aX+b\right] = a\,\mathrm{E}\left[X\right] + b, \quad \mathrm{E}\left[b\right] = b.$$

Variance

The *variance* of a random variable X is given by

$$\mathrm{Var}\left(X\right) = \mathrm{E}\left[(X-\mu)^2\right] = \mathrm{E}\left[X^2\right] - \mu^2,$$

where μ denotes the expectation of X, $\mathrm{E}\left[X\right]$.
When X is a continuous random variable with PDF $f(x)$,

$$\mathrm{E}\left[X^2\right] = \int_{-\infty}^{\infty} x^2 f(x) dx$$

Example

X induces a *uniform distribution* on $(0,1)$. X has PDF $f(x) = 1$ for $x \in (0,1)$ and 0 otherwise. We have computed that $\mathrm{E}\left[X\right] = 0.5$

$$\mathrm{Var}\left(X\right) = \int_{-\infty}^{\infty} x^2 f(x) dx - \mathrm{E}\left[X\right]^2 = \int_0^1 x^2 dx - \frac{1}{2^2} = \left.\frac{x^3}{3}\right|_0^1 - \frac{1}{4} = \frac{1}{12}.$$

Properties of variances

Given two random variables X, Y such that $\mathrm{E}\left[|X|\right] < \infty, \mathrm{E}\left[|Y|\right] < \infty$. Take any $a, b \in \mathbb{R}$. We have seen that

$$\mathrm{E}\left[X+Y\right] = \mathrm{E}\left[X\right] + \mathrm{E}\left[Y\right], \quad \mathrm{E}\left[aX+b\right] = a\,\mathrm{E}\left[X\right] + b, \quad \mathrm{E}\left[b\right] = b.$$

Then

$$\begin{aligned} \mathrm{Var}\left(aX+b\right) &= \mathrm{E}\left[(aX+b-\mathrm{E}\left[aX+b\right])^2\right] = \mathrm{E}\left[(aX+b-a\,\mathrm{E}\left[X\right]-b)^2\right] \\ &= a^2\,\mathrm{E}\left[(X-\mathrm{E}\left[X\right])^2\right] = a^2\,\mathrm{Var}\left(X\right). \end{aligned}$$

In particular, we have

$$\mathrm{Var}\left(b\right) = 0, \quad \mathrm{Var}\left(X+b\right) = \mathrm{Var}\left(X\right), \quad \mathrm{Var}\left(aX\right) = a^2\,\mathrm{Var}\left(X\right).$$

Variance of the standard normal random variable

Example

Let Z be a random variable that induces the standard normal distribution. We know that

$$f(z) = \frac{1}{\sqrt{2\pi}} \exp\left(-\frac{z^2}{2}\right),$$

and $\mathrm{E}[Z] = 0$

$$\mathrm{Var}(Z) = \mathrm{E}\left[Z^2\right] - 0 = \int_{-\infty}^{\infty} z^2 f(z) dz = \frac{1}{\sqrt{2\pi}} \int_{-\infty}^{\infty} z^2 \exp\left(-\frac{z^2}{2}\right) dz = 1.$$

We write $Z \sim \mathcal{N}(0, 1)$ to indicate that Z induces a standard normal distribution with mean 0 and variance 1.

z_α

Given any $\alpha \in (0,1)$, we define z_α such that

$$P(Z > z_\alpha) = 1 - \Phi(z_\alpha) = \alpha, \quad \text{i.e.} \quad \Phi(z_\alpha) = 1 - \alpha.$$

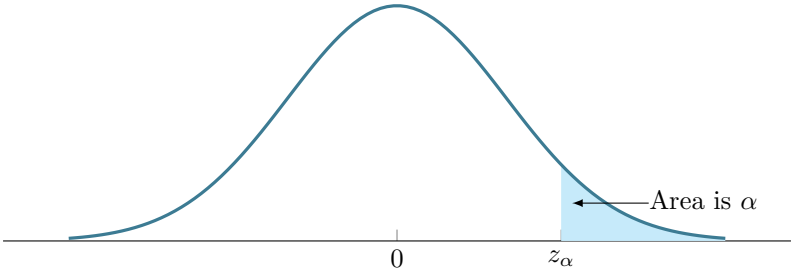


Figure: Probability density function $f(z)$ for $Z \sim \mathcal{N}(0,1)$. $P(Z > z_\alpha) = \alpha$, α corresponds to the area under $f(z)$ for $z > z_\alpha$.

z_α

α	0.1	0.05	0.01	0.005	0.001
$1-\alpha$	0.900	0.950	0.990	0.995	0.999
z_α	1.282	1.645	2.326	2.576	3.090

Table: A few values of z_α with corresponding α.

Normal random variable

- Let $Z \sim \mathcal{N}(0,1)$ be a standard normal random variable
- Take any $\sigma, \mu \in \mathbb{R}$ with $\sigma^2 > 0$
- Define $Y = \sigma Z + \mu$
- It can be shown that Y has PDF

$$f(y) = \frac{1}{\sigma\sqrt{2\pi}} \exp\left(-\frac{(y-\mu)^2}{2\sigma^2}\right).$$

  And

$$\mathrm{E}[Y] = \mu, \quad \mathrm{Var}(Y) = \sigma^2$$

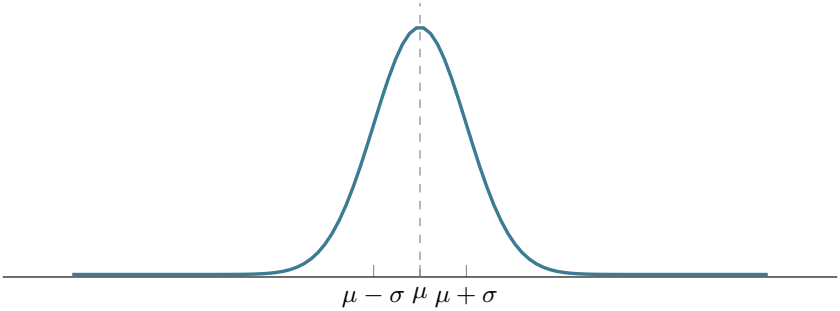
- We say that Y induces a *normal distribution with mean μ and variance σ^2*, written $Y \sim \mathcal{N}(\mu, \sigma^2)$. Y is also called *normal/a normal random variable*. We note that the mean and variance fully define a normal distribution.

Normal random variable

$f(y)$ is a bell-shaped curve symmetric about μ and obtains its maximum value of

$$\frac{1}{\sigma\sqrt{2\pi}} \approx \frac{0.399}{\sigma}$$

at $y = \mu$



Independent random variables

Definition

Given two random variables $X : \Omega \to \mathbb{R}$, $Y : \Omega \to \mathbb{R}$, they are said to be *independent* if for any $A, B \in \mathcal{R}$,

$$P(X \in A, Y \in B) = P(X \in A)P(Y \in B).$$

Here $\mathcal{R}$ denotes the *Borel set*, a set of subsets of $\mathbb{R}$, which contains open sets, closed set, etc.

If two random variables $X : \Omega \to \mathbb{R}$, $Y : \Omega \to \mathbb{R}$ are independent, it can be proven that

$$\mathrm{E}[XY] = \mathrm{E}[X]\,\mathrm{E}[Y] \quad \text{if} \quad \mathrm{E}[|X|] < \infty \text{ and } \mathrm{E}[|Y|] < \infty.$$

Covariance

- To analyze the relation between two random variables X and Y, we define the *covariance* of X and Y to be

$$\mathrm{Cov}\,(X, Y) = \mathrm{E}\,[(X - \mathrm{E}\,[X])(Y - \mathrm{E}\,[Y])]\,.$$

- It can be shown that

$$\mathrm{Cov}\,(X, Y) = \mathrm{E}\,[XY] - \mathrm{E}\,[X]\,\mathrm{E}\,[Y]\,.$$

- It is easy to see that $\mathrm{Cov}\,(X, Y) = \mathrm{Cov}\,(Y, X)$ and $\mathrm{Cov}\,(X, X) = \mathrm{Var}\,(X)$.

Definition

Let X and Y be two random variables. If $\mathrm{Cov}\,(X, Y) = 0$, we say that X and Y are *uncorrelated*. Otherwise, we say that X and Y are correlated.

Correlation coefficient

Definition

Let X and Y be two random variables with positive finite variances. The *correlation coefficient* of X and Y is given by

$$\rho = \frac{\mathrm{Cov}\,(X, Y)}{\sqrt{\mathrm{Var}\,(X)\,\mathrm{Var}\,(Y)}}.$$

- $-1 \leq \rho \leq 1$
- The correlation coefficient helps answer the question of whether large values of X tend to be paired with large values of Y or with small values of Y.
- If when X is large (or small), Y is also large (or small), then the signs of $X - \mathrm{E}\,[X]$ and $Y - \mathrm{E}\,[Y]$ will tend to be the same. And the absolute value of ρ will be bigger.
- If when X is large (or small), Y is small (or large), then the signs of $X - \mathrm{E}\,[X]$ and $Y - \mathrm{E}\,[Y]$ will tend to be different. And the absolute value of ρ will be bigger.
- In the special case when X and Y are uncorrelated, $\rho = 0$.
- In particular, if X and Y are independent, then $\rho = 0$

Probability theory and introduction to SCA

- Probability Measure
- Random Variable
- Side-channel Analysis
- Side-channel Leakages
- Leakage Assessment

Why are we interested in physical attacks?

- Cryptography provides algorithms that enable secure communication in theory
- In the real world, these algorithms have to be implemented on real devices:
  - software implementations: general-purpose devices
  - hardware implementations: dedicated secure hardware devices
- To evaluate the security level of cryptographic implementations, it is necessary to include a physical security assessment

Different physical attack methods

- Side-channel analysis attacks
  - EM/Power analysis
  - Timing analysis
  - Cache attacks
- Fault attacks
  - Optical fault injection
  - Electromagnetic fault injection
  - Clock/voltage glitch
- Hardware Trojans
- ...

picture source: https://nl.dreamstime.com/stock-foto-s-hamer-die-computer-boos-tonen-raken-image34210923

Side-channel analysis attacks

- Side-channel analysis attacks passively target cryptographic implementations.
- These attacks exploit the possibility that an attacker can observe physical characteristics of a device running a cryptographic algorithm.
- The attacker obtains side-channel information, e.g. power consumption, electromagnetic emanations, or execution time, and then uses such information to recover the secret key.
- In this course, we will focus on power analysis attacks that exploit power consumption information.
- Similar attack methodologies can also be applied when electromagnetic (EM) emanations are analyzed.

Remark

We use the terminology *side-channel analysis* attacks only in the narrower meaning which refers to power analysis attacks. In short, we also write side-channel analysis as *SCA*.

Device under test (DUT)

- The device from which we take measurements is called the *device under test (DUT)*.
  - A microcontroller running a software implementation
  - An FPGA or ASIC realizing a hardware implementation.
- We assume the attacker has certain knowledge of the implementation.
  - How to interface with the encryption routine
  - Whether the computation is executed serially or in parallel
  - Whether some types of countermeasures are present
  - Generally, this type of information can be also obtained by reverse engineering, visual inspection of the side-channel measurements, or sometimes just with a simple trial-and-error technique.

Attacker goal

- The ultimate goal of the attacker is to recover the master key of a symmetric block cipher or the private key of a public-key cipher.

Non-profiled SCA

- If the attacker does not have access to a similar device, just the target device or just the measurements coming from the target device, we talk about a *non-profiled SCA*.
- In a general scenario, this attack utilizes a set of measurements where a fixed secret key is used to encrypt multiple (random) plaintexts.

Profiled SCA

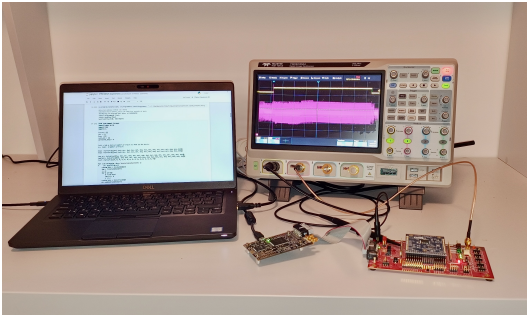
- If we assume the attacker has access to a clone device of the target device, then the attacker can carry out a *profiled SCA*.
- The attack operates in two phases.
- In the profiling phase, the attacker acquires side-channel measurements for known plaintext/ciphertext and known key pairs.
  - This set of data is used to characterize or model the device.
- Then the attacker acquires a few measurements from the target device, usually identical to the clone device, with known plaintext/ciphertext but the key is secret.
  - These measurements from the target device are then tested against the characterized model from the clone device.

Measurement device

- Power analysis measures the *power consumption* of the device under attack indirectly through a voltage signal.
- In practice, the most convenient device for capturing the voltage change over time is a digital sampling oscilloscope.
- Such a device takes samples of the measured voltage signal over time.
- We refer to each sample point as a *time sample*.

Setup

- Ready-to-use measurement platform NewAE ChipWhisperer-Lite (black in the middle) – handling the communication with the DUT and the acquisition.
- CW 308 UFO board (red) – a breakout board with the DUT – ARM Cortex-M4 (blue) mounted on top.
- The controlling and data processing were done from a laptop, from the Jupyter environment available for the ChipWhisperer platform.
- Teledyne T3DSO3504 benchtop oscilloscope, used mainly for convenience purposes – to precisely locate the time intervals in the initial analysis stage.



Trigger

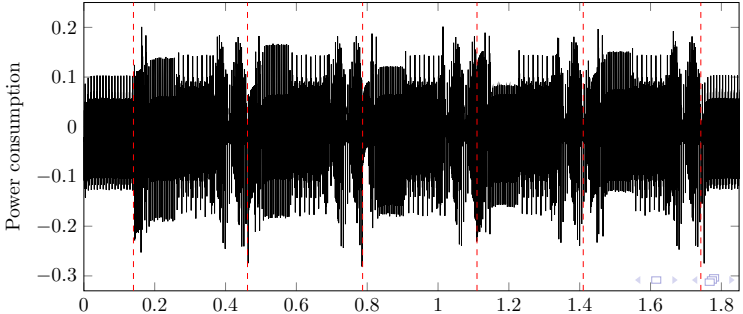
- An important task during the acquisition is capturing the correct time window corresponding to the operations we want to measure.
- In laboratory conditions, it is common to use an artificial trigger signal that indicates the start/end of the encryption.
- In real-world settings, it is necessary to identify the correct position by examining the captured signal – this is usually done based on the evaluator's expertise.

Power trace

- In our experiments, a trigger signal is raised high during the computation that we want to capture and lowered afterward.
- One measurement consists of the recorded values for each *time sample* during this interval.
- It can be stored in an array whose length equals the total number of time samples in the measured interval.
- It can also be shown as a graph where the x-axis corresponds to time samples and the y-axis shows the measured values.
- We refer to the result of one measurement as a *(power) trace*.
- Note that, for ChipWhisperer, the y-axis does not show the actual voltage value but a 10-bit value proportional to the current through the shunt resistor.

One trace

- The figure shows one power trace for the first five rounds of PRESENT encryption.
- A sequence of `nop` instructions was inserted before and after the cipher computation.
- Certain patterns can be seen in the trace, and we can relate them to the corresponding operations in different time intervals.
- For example, time samples 0–312 and 2778–3100 correspond to `nop` instructions.
- The five repeated patterns, indicated by red dotted lines, correspond to the five rounds.



Datasets

There are four datasets that will be analyzed in more detail in the course.
All the datasets:

- capture one round of a software implementation of PRESENT;
- include `nop` instructions before and after the PRESENT computation;
- are analyzed in shortened form with 3600 time samples per trace.

More details on individual datasets:

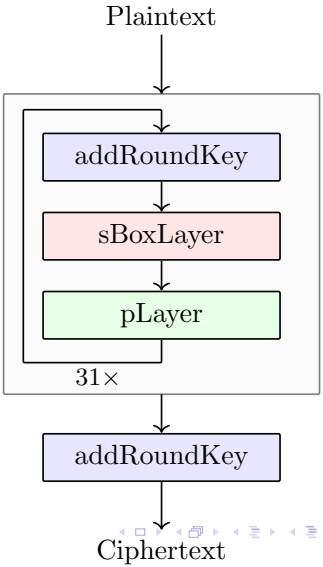
- *Fixed dataset A*: This dataset contains 5000 traces with a fixed round key `0xFEDCBA0123456789` and a fixed plaintext `0xABCDEF1234567890`.
- *Fixed dataset B*: This dataset contains 5000 traces with a fixed round key `0xFEDCBA0123456789` and a fixed plaintext `0x84216BA484216BA4`.
- *Random plaintext dataset*: This dataset contains 5000 traces with a fixed round key `0xFEDCBA0123456789` and a random plaintext for each trace.
- *Random dataset*: This dataset contains 10000 traces with a random round key and a random plaintext for each trace.

PRESENT – encryption

- Block length: $n = 64$
- Number of rounds: $\texttt{Nr} = 31$
- Key length: either 80 or 128.
- Round function: addRoundKey, sBoxLayer, and pLayer.
- After 31 rounds, addRoundKey is applied again before the ciphertext output

Remark

For PRESENT specification, we consider the 0th bit of a value as the rightmost bit in its binary representation. For example, the 0th bit of $3 = 011_2$ is 1, the 1st bit is 1 and the 2nd bit is 0.



Attack methods

- Classical power analysis attack methods
  - *Simple power analysis (SPA)*
  - *Differential power analysis (DPA)*
- SPA assumes the attacker has access to only one or a few measurements corresponding to some fixed inputs.
- DPA assumes the attacker can take measurements for a potentially unlimited number of different inputs.

Probability theory and introduction to SCA

- Probability Measure
- Random Variable
- Side-channel Analysis
- Side-channel Leakages
- Leakage Assessment

Leakages

- In the later parts of the course, we will see that by analyzing the power consumption, we can deduce the secret key. Consequently, we also refer to the power consumption as the *leakage* of the device.
- We consider the leakage to consist of two parts: *signal* and *noise*.
- Signal refers to the part of the leakage that contains useful information for our attack and the rest is noise.
  - For example, suppose we would like to recover the Hamming weight of an intermediate value. In that case, the part of the leakage correlated with the Hamming weight of that intermediate value is our signal.

Leakage is dependent on the operations being executed

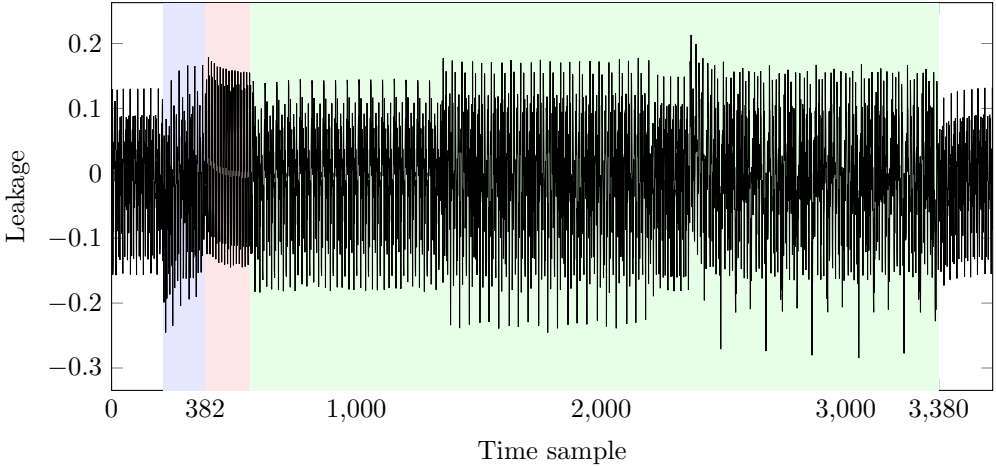


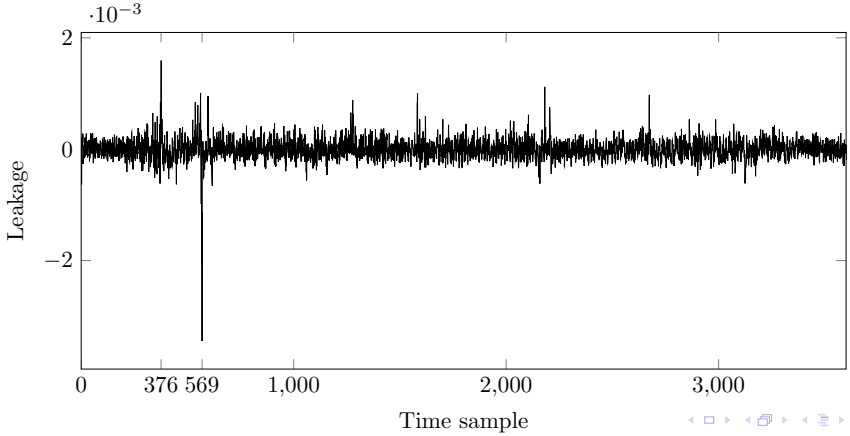
Figure: The averaged trace for 5000 traces from the *Fixed dataset A*. The blue, pink, and green parts of the trace correspond to addRoundKey, sBoxLayer, and pLayer respectively.

Leakage is dependent on the data being processed

- 1000 traces: each for a random plaintext with the 0th bit equal to 0; Take the average
- 1000 traces: each for a random plaintext with the 0th bit equal to 1; Take the average
- Take the difference trace of those two averages

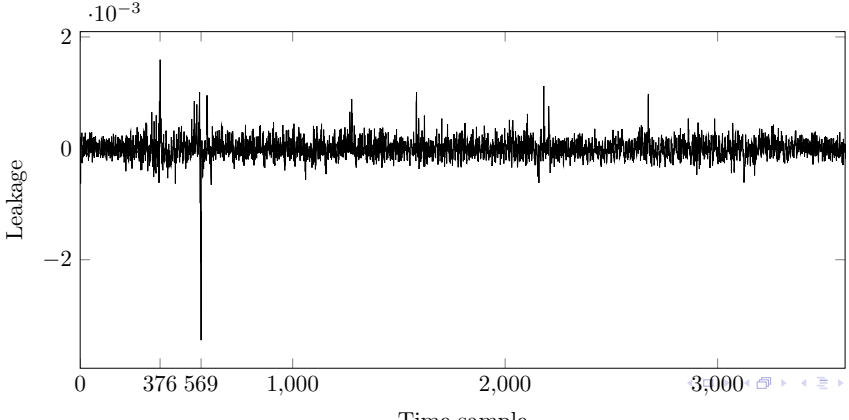
Leakage is dependent on the data being processed

- A few peaks in the difference trace and apart from those peaks, most of the points are close to zero.
- Those peaks indicate that at the corresponding time samples, the 0th bit of the plaintext is involved in the computations.



Leakage is dependent on the data being processed

- Compared with the averaged trace of one round of PRESENT, the first peak most likely corresponds to addRoundKey.
- The second prominent peak most likely corresponds to pLayer.
- These observations illustrate that the leakage depends on the data being processed in the DUT.



Remark

- SPA typically exploits the relationship between the executed operations and the leakage.
- DPA focuses on the relationship between the processed data and the leakage.

Distribution of leakages

- For a fixed time sample t, let L_t, X_t, and N_t denote the random variables corresponding to the leakage, signal, and noise, respectively:

$$L_t = X_t + N_t.$$

- We assume that X_t and N_t are independent (the "independent noise assumption").
- If we fix both the operation and the data, then the signal is constant, i.e. X_t is a constant.
  - In that case, the variations in the leakage are caused by the noise.
  - As an example, we can use *Fixed dataset A*, which contains 5000 traces with a fixed round key and a fixed plaintext.

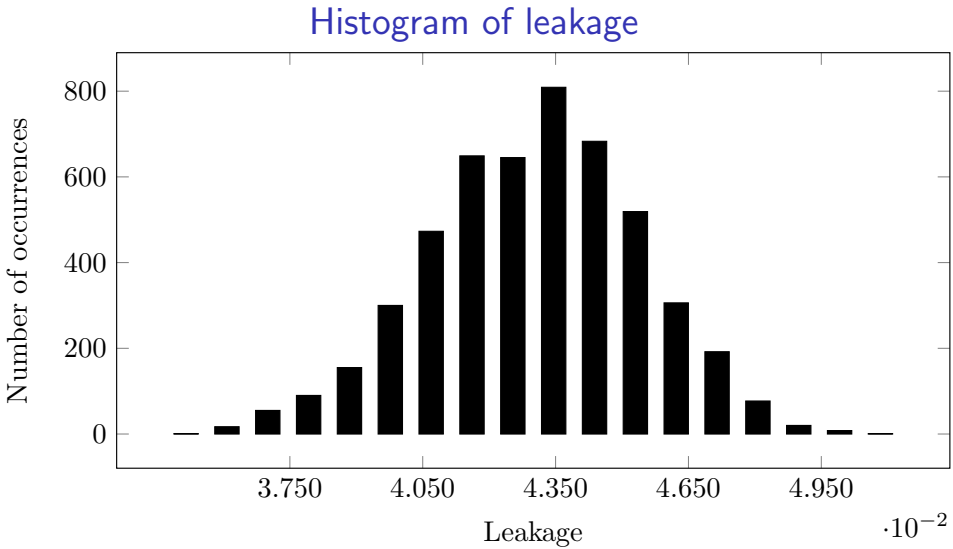


Figure: Histogram of leakages at $t = 3520$ across 5000 traces from the *Fixed dataset A*. $t = 3520$ corresponds to `nop` operations

Histogram of leakage

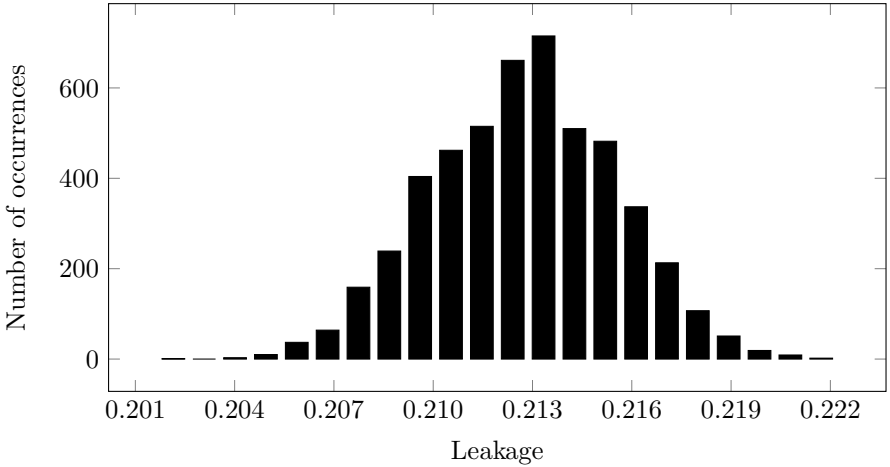


Figure: Histogram of leakages at $t = 2368$ across 5000 traces from the *Fixed dataset A*. $t = 2368$ corresponds to the highest peak in the averaged trace of *Fixed dataset A*– pLayer.

Distribution of leakages

- We fix the operation and the data, and we get a constant signal, i.e. X_t is a constant
  - The variants in the leakage will be caused by the noise
  - We approximate the distribution induced by L_t with a normal distribution

$$L_t \sim \mathcal{N}(\mu_t, \sigma_t^2).$$

$$\mathrm{E}\left[L_t\right] = X_t + \mathrm{E}\left[N_t\right], \quad \mathrm{Var}\left(L_t\right) = \mathrm{Var}\left(N_t\right).$$

Probability theory and introduction to SCA

- Probability Measure
- Random Variable
- Side-channel Analysis
- Side-channel Leakages
- Leakage Assessment

Motivation

- In the next few weeks, we will see various SCA attacks on cryptographic implementations.
- As a developer, one might want to evaluate the DUT and conclude if it is vulnerable against SCA or not.
- Different new attacks are being developed and it is impractical to verify the security of our device against all of them.
- Leakage assessment aims to solve this problem by analyzing the power trace and answering the question of whether any input-dependent information can be detected in the traces of the DUT.
- We will see a method based on the student's t-test.
- The methodology is also referred to as *test vector leakage assessment (TVLA)*.

Remark

- Leakage assessment methods do not provide any conclusions in cases where data-dependent leakage is not detected.
- The absence of data-dependent leakage indicated by a particular method does not prove that the implementation is leakage-free.

Properties of expectations and variances

Given two random variables X, Y such that $\mathrm{E}\left[|X|\right] < \infty, \mathrm{E}\left[|Y|\right] < \infty$. Take any $a, b \in \mathbb{R}$. Then

$$\mathrm{E}\left[X+Y\right] = \mathrm{E}\left[X\right] + \mathrm{E}\left[Y\right], \quad \mathrm{E}\left[aX+b\right] = a\,\mathrm{E}\left[X\right] + b, \quad \mathrm{E}\left[b\right] = b.$$

And

$$\mathrm{Var}\left(b\right) = 0, \quad \mathrm{Var}\left(X+b\right) = \mathrm{Var}\left(X\right), \quad \mathrm{Var}\left(aX\right) = a^2\,\mathrm{Var}\left(X\right).$$

Modelling leakages

- Fix a time sample t.
- Let L_t denote the random variable corresponding to the leakage at time sample t.
- When the data being processed in the DUT is fixed, we approximate the leakage by
$$L_t \sim \mathcal{N}(\mu_t, \sigma_t^2).$$
- Since we focus on one time sample, the operation is also fixed.
- Hence the signal X_t, which depends only on the operation and/or the processed data, is fixed.
- Since
$$L_t = X_t + N_t,$$
the properties of expectation and variance give
$$\mu_t = X_t + \mathrm{E}\left[N_t\right], \quad \sigma_t^2 = \mathrm{Var}\left(N_t\right).$$

Leakages for two plaintexts

- Let L_t and L'_t denote the leakages at time sample t for encryptions of two different plaintexts.
- We write

$$L_t = X_t + N_t, \quad L'_t = X'_t + N'_t,$$

with

$$L_t \sim \mathcal{N}(\mu_t, \sigma_t^2), \quad L'_t \sim \mathcal{N}(\mu'_t, \sigma_t'^2).$$

- We take the signal to be the part of the leakage related to the plaintext value.
- Under the usual assumption that the noise behavior is the same in both cases, we have

$$\mathrm{E}\left[N_t\right] = \mathrm{E}\left[N'_t\right], \quad \mathrm{Var}\left(N_t\right) = \mathrm{Var}\left(N'_t\right).$$

- Consequently,

$$\mu_t - X_t = \mu'_t - X'_t, \quad \sigma_t^2 = \sigma_t'^2.$$

Equal signal

- We have seen before that the leakage L_t is dependent on the data being processed in the device.
- In fact, certain SCA attacks (e.g. DPA) exploit the dependency of the leakage on data.
- If the leakage is *not* exploitable, we would expect, at least, that the signals at time sample t should be the same when the only difference is the values of the data being processed.
- With our notations, this means that we would like to test if

$$X_t = X'_t, \quad \text{and equivalently} \quad \mu_t = \mu'_t.$$

Sample

- For a given random experiment, the *sample space*, denoted by Ω, is the set of all possible outcomes.
- A random variable $X : \Omega \to \mathbb{R}$.
- $X \sim \mathcal{N}(\mu_x, \sigma_x^2)$: normal random variable
- We repeat the random experiment n times and record the outcomes.
- Then $X_1, X_2, \ldots, X_n$ are n independent and identically distributed random variables.
- We refer to the collection $(X_1, X_2, \ldots, X_n)$ as a *sample*.

Sample mean and sample variance

The *sample mean (empirical mean)*, denoted $\overline{X}$, is given by

$$\overline{X} := \frac{1}{n}\sum_{i=1}^{n} X_i.$$

The *sample variance (empirical variance)*, denoted S_x^2, is given by

$$S_x^2 := \frac{1}{n-1}\sum_{i=1}^{n}(X_i - \overline{X})^2.$$

Remark

The sample mean and sample variance are random variables. A realization of $\overline{X}$ and S_x^2 are represented as $\overline{x}$ and s_x^2.

Statistical hypothesis

- *Statistical hypothesis*: a statement about the parameters of an unknown distribution
- We call such a statement hypothesis because it is not known whether or not it is true.
- We will use **samples** from an unknown distribution to draw certain conclusions regarding a given hypothesis about this distribution.
- A procedure for determining whether or not the values of a sample are consistent with the hypothesis.
- The decision will then be either to *reject* the null hypothesis or to *fail to reject* it.
- If we fail to reject the null hypothesis, we conclude only that the resulting data from the sample appear to be consistent with it.

Example (Example of a hypothesis)

If we are interested in whether $\mu_t = \mu'_t$, we can set a hypothesis that $\mu_t = \mu'_t$.

Samples for TVLA

- Two datasets, each with M traces
- Encryption of one plaintext
- Encryption of another plaintext
- We will use
  - *Fixed dataset A*: This dataset contains 5000 traces with a fixed round key `0xFEDCBA0123456789` and a fixed plaintext

    $$p_1 = \texttt{ABCDEF1234567890}.$$

  - *Fixed dataset B*: This dataset contains 5000 traces with a fixed round key `0xFEDCBA0123456789` and a fixed plaintext

    $$p_2 = \texttt{0x84216BA484216BA4}.$$

- L_t: leakage for encryption of p_1 at time sample t. We will take *Fixed dataset A* as a sample for L_t
- L'_t: leakage for encryption of p_2 at time sample t. We will take *Fixed dataset B* as a sample for L'_t.

Statistical hypothesis

- The hypothesis that we want to test is called the *null hypothesis*, denoted by H_0.
- For example
$$H_0 : \mu_t = \mu'_t, \quad H_0 : \mu_t \geq \mu'_t.$$
- We will test the null hypothesis against an *alternative hypothesis*, denoted by H_1. For example
$$H_1 : \mu_t \neq \mu'_t, \quad H_1 : \mu_t > \mu'_t.$$
- For TVLA, the null and alternative hypotheses are:
$$H_0 : \mu_t = \mu'_t, \quad H_1 : \mu_t \neq \mu'_t.$$

Example

Let $t = 392$, the null and alternative hypotheses are
$$H_0 : \mu_{392} = \mu'_{392}, \quad H_1 : \mu_{392} \neq \mu'_{392}.$$

t-value

$$t\text{-value}_t := \frac{\overline{l_t} - \overline{l'_t}}{\sqrt{\frac{s_t^2 + {s'_t}^2}{M}}},$$

- $\overline{l_t}$: realization of the sample mean for L_t
- s_t^2: realization of the sample variance for L_t
- $\overline{l'_t}$: realization of the sample mean for L'_t
- ${s'_t}^2$: realization of the sample variance for L'_t
- M: the number of traces

t-value – Example

Example

Let $t = 392$. We can compute the sample mean and sample variance of L_{392} with *Fixed dataset A*:

$$\overline{l_{392}} \approx -0.0525, \quad s_{392}^2 \approx 1.5141 \times 10^{-6}.$$

With *Fixed dataset B*, we compute the sample mean and sample variance of L'_{392}:

$$\overline{l'_{392}} \approx -0.0501, \quad s_{392}^{\prime 2} \approx 1.4801 \times 10^{-6}.$$

We set the following hypotheses

$$H_0 : \mu'_{392} = \mu_{392}, \quad H_1 : \mu'_{392} \neq \mu_{392}.$$

According to student's t-test, we calculate

$$\frac{|\overline{l'_{392}} - \overline{l_{392}}|}{\sqrt{\frac{s_{392}^2 + s_{392}^{\prime 2}}{5000}}} = \frac{0.0024}{\sqrt{\frac{1.5141 \times 10^{-6} + 1.4801 \times 10^{-6}}{5000}}} \approx 98.1$$

z_α

Given any $\alpha \in (0,1)$, we define z_α such that

$$P(Z > z_\alpha) = 1 - \Phi(z_\alpha) = \alpha, \quad \text{i.e.} \quad \Phi(z_\alpha) = 1 - \alpha.$$

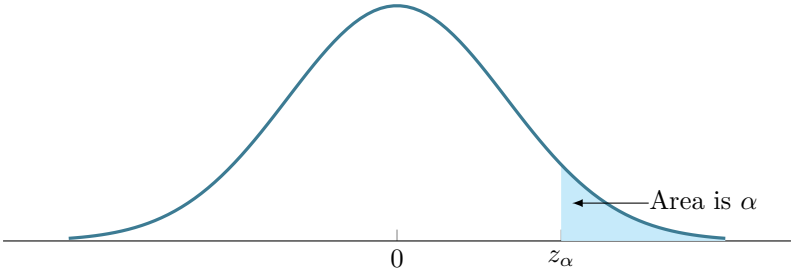


Figure: Probability density function $f(z)$ for $Z \sim \mathcal{N}(0,1)$. $P(Z > z_\alpha) = \alpha$, α corresponds to the area under $f(z)$ for $z > z_\alpha$.

Student's t-test

- *level of significance of the test*, α: when H_0 is true, the probability of rejecting it is not bigger than α.

$$P\left(\text{reject } H_0 | H_0 \text{ is true}\right) \leq \alpha.$$

- Given α, the procedure of hypothesis testing is to find the correct condition for rejecting/accepting H_0
- Student's t-test: reject H_0 if $|t\text{-value}_t| > z_{\alpha/2}$

$$P\left(|t\text{-value}_t| > z_{\alpha/2} \;\middle|\; H_0 \text{ is true}\right) = \alpha.$$

α	0.1	0.05	0.01	0.005	0.001
z_α	1.282	1.645	2.326	2.576	3.090

Student's t-test

$$H_0 : \mu_{392} = \mu'_{392}, \quad H_1 : \mu_{392} \neq \mu'_{392}.$$

Student's t-test: reject H_0 if $|t\text{-value}_t| > z_{\alpha/2}$

$$P\left(|t\text{-value}_t| > z_{\alpha/2} \mid H_0 \text{ is true}\right) = \alpha.$$

α	0.1	0.05	0.01	0.005	0.001
z_α	1.282	1.645	2.326	2.576	3.090

Example

- For $t = 392$, we have computed $|t|\text{-value}_{392} \approx 98.1$. Take $\alpha = 0.01$, then $z_{\alpha/2} = 2.576$.
- $98.1 > 2.576$. By the student's t-test with a level of significance, 0.01 is to reject H_0.
- We conclude that $\mu_{392} \neq \mu'_{392}$
- The probability that our conclusion is wrong is $\alpha = 0.01$.

What does the conclusion mean to us

- Certain SCA attacks (e.g. DPA) exploit the dependency of the leakage on data.
- If the leakage L_t is *not* exploitable, we would expect, at least, that the signals at time sample t should be the same when different values of the data are being processed at this specific time.
- This means:

$$X_t = X'_t, \quad \text{and equivalently} \quad \mu_t = \mu'_t.$$

- When we take the signal to be part of the leakage correlated to the plaintext value, our example concludes that the signals at time sample 392 for encryption of plaintexts `ABCDEF1234567890` and `84216BA484216BA4` are very likely to be different, according to our measurements *Fixed dataset A* and *Fixed dataset B*.
- The probability of the conclusions being wrong is 0.01.

TVLA threshold

Following the convention for TVLA, we set $z_{\alpha/2} = 4.5$. By definition, this threshold corresponds to

$$\frac{\alpha}{2} = 1 - \Phi(z_\alpha) = 1 - \Phi(4.5) = 1 - 0.9999966023268753 \approx 3.4 \times 10^{-6}.$$

The significance level is given by

$$\alpha \approx 6.8 \times 10^{-6}.$$

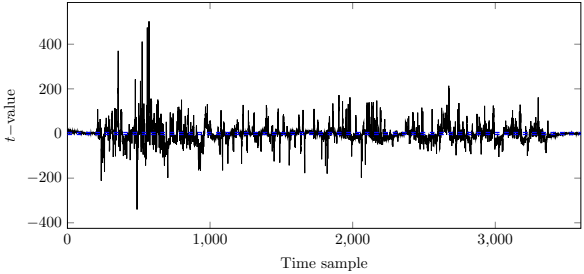
This means that the probability of rejecting the null hypothesis (i.e. conclude that the means are different) when it is actually true (i.e. the means are in fact the same) is approximately

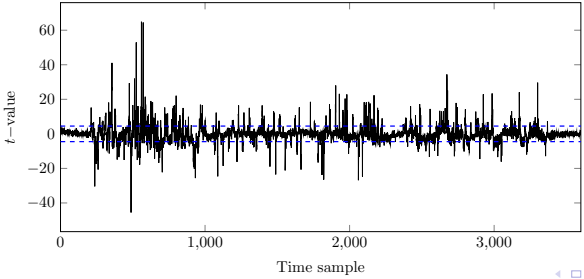
$$\alpha \approx 6.8 \times 10^{-6}.$$

TVLA procedure

- Fix the master key
- Measure M traces for one fixed plaintext
- Measure M traces for another fixed plaintext
- For each time sample t
  - Compute the t-values with the two sets of traces
  - Compare the t-value with the threshold 4.5 and -4.5

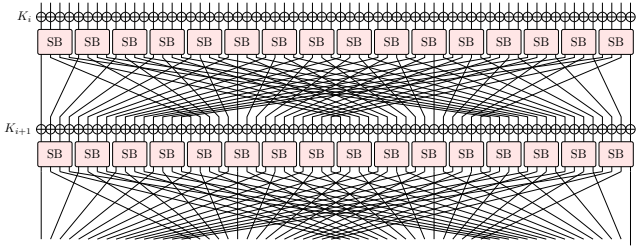
TVLA results – 5000 and 50 traces



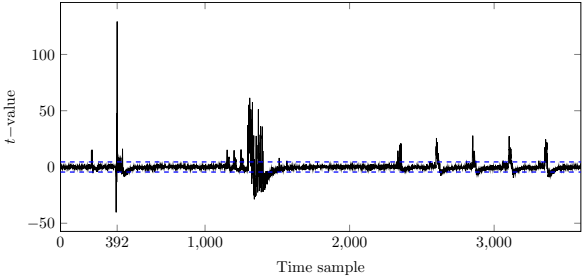


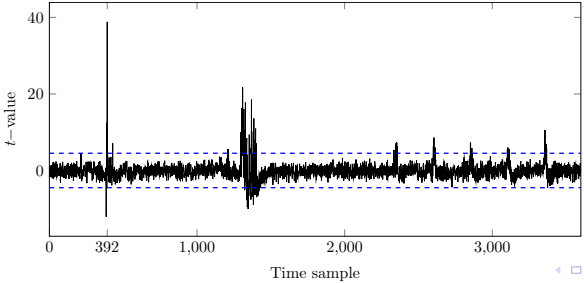
Other settings

- We can also have different numbers of traces for those two measurements - another formula for t-value
- We have seen fixed vs. fixed (two different fixed plaintexts). Can also have fixed vs. random (a fixed plaintext, random plaintexts) – Welch's t-test
- Instead of fixing the plaintext, we can also fix one intermediate value, e.g. the 0th Sbox output of PRESENT



TVLA results – Sbox output – fixed vs. fixed – *Random dataset*





Code

- A simplified code for TVLA with Sbox output as the fixed intermediate value can be found here

https://github.com/XIAOLUHOU/SCA-measurements-and-analysis----Experimental-results-for-textbook/blob/main/Assignment_materials/TVLA.ipynb

- All datasets and analysis code related to SCA can be found here

https://github.com/XIAOLUHOU/SCA-measurements-and-analysis----Experimental-results-for-textbook/tree/main

Observations

- When more traces are used (i.e. when the sample size is bigger), it is more likely for us to capture information about the inputs from the leakages. We will see next week that more traces indeed indicate higher chances for the attacks to be successful.
- When we take the signal to be the 0th Sbox output, the highest $|t|$-value is obtained at time sample 392. We will see that this is a *point of interest* (POI) for the attack, i.e. a sample point that gives particularly strong attack performance.
- Compared to the signal being the plaintext, the $|t|$-values are in general smaller with much fewer times samples crossing the threshold when the signal is given by an Sbox output. This is unsurprising as we would expect more computations to be correlated with the plaintext rather than a single Sbox output.

More about leakage assessment

- TVLA was first proposed in 2011[1]
- More discussions on how to set the threshold[2]
- Another prominent leakage assessment method: Pearson's χ^2-test[3]

[1] Gilbert Goodwill, B. J., Jaffe, J., & Rohatgi, P. (2011, September). A testing methodology for side-channel resistance validation. In NIST non-invasive attack testing workshop (Vol. 7, pp. 115-136).

[2] Ding, A. A., Zhang, L., Durvaux, F., Standaert, F. X., & Fei, Y. (2017, November). Towards sound and optimal leakage detection procedure. In International Conference on Smart Card Research and Advanced Applications (pp. 105-122). Springer, Cham.

[3] Schneider, T., & Moradi, A. (2015). Leakage assessment methodology: A clear roadmap for side-channel evaluations. In Cryptographic Hardware and Embedded Systems–CHES 2015: 17th International Workshop, Saint-Malo, France, September 13-16, 2015, Proceedings 17 (pp. 495-513). Springer Berlin Heidelberg.